

# WEBSITE VULNERABILITY ASSESSMENT REPORT

---

Target:

**<http://zero.webappsecurity.com/>**

Prepared by:

**Sunny Abraham Mathew**

Report Date: 25-06-2026

**Classification: CONFIDENTIAL**

---

## Table of Contents

|   |                                                                                       |    |
|---|---------------------------------------------------------------------------------------|----|
| □ | <b>Table of Contents</b>                                                              | 2  |
| □ | <b>1. Executive Summary</b>                                                           | 3  |
| • | 1.1 Engagement Overview                                                               | 3  |
| • | 1.2 Summary of Findings                                                               | 3  |
| □ | <b>2. Methodology</b>                                                                 | 4  |
| • | 2.1 Testing Phases                                                                    | 4  |
| □ | <b>3. Findings Summary</b>                                                            | 4  |
| □ | <b>4. Findings</b>                                                                    | 6  |
| • | 4.1 VULN-01: Content Security Policy (CSP) Header Not Set                             | 6  |
| • | 4.2 VULN-02: Cross-Domain Misconfiguration                                            | 6  |
| • | 4.3 VULN-03: Exposed server-status Page                                               | 7  |
| • | 4.4 VULN-04: Missing Anti-clickjacking Header                                         | 7  |
| • | 4.5 VULN-05: Vulnerable JS Library                                                    | 8  |
| • | 4.6 VULN-06: In Page Banner Information Leak                                          | 8  |
| • | 4.7 VULN-07: Server Leaks Version Information via "Server" HTTP Response Header Field | 9  |
| • | 4.8 VULN-08: X-Content-Type-Options Header Missing                                    | 9  |
| • | 4.9 VULN-09: Expired SSL Certificate                                                  | 10 |
| • | 4.10 VULN-10: SSLv2 Enabled                                                           | 10 |
| • | 4.11 VULN-11: Outdated, End-of-Life Software Stack                                    | 10 |
| • | 4.12 VULN-12: Risky HTTP Methods (PUT/DELETE/TRACE/PATCH)                             | 11 |
| • | 4.13 VULN-13: Weak Transport Security Due to Expired SSL/TLS Certificate              | 11 |
| □ | <b>5. Conclusion &amp; Recommendations</b>                                            | 12 |
| • | 5.1 Prioritized Remediation Roadmap                                                   | 12 |

---

## 1. Executive Summary

---

A passive reconnaissance and vulnerability assessment was conducted against the training application hosted at <http://zero.webappsecurity.com/> as part of the Future Interns Internship Program. Security testing was performed using industry-standard tools including OWASP ZAP, Nmap, and Burp Suite. The assessment identified a total of 13 security vulnerabilities and misconfigurations requiring remediation to improve the application's overall security posture.

### 1.1 Engagement Overview

**Target:** <http://zero.webappsecurity.com/>

**Assessment Type:** Passive Scan

**Conducted By:** Sunny Abraham Mathew

### 1.2 Summary of Findings

During the assessment, a total of 13 vulnerabilities were identified across the target application(s). The table below summarizes findings by severity.

| Severity | Count |
|----------|-------|
| CRITICAL | 1     |
| HIGH     | 3     |
| MEDIUM   | 6     |
| LOW      | 3     |
| Total    | 13    |

---

## 2. Methodology

---

### 2.1 Testing Phases

- Reconnaissance & Information Gathering — [passive recon, technology fingerprinting]
- OWASP ZAP
- Nmap
- DevTools

## 3. Findings Summary

The table below lists all findings identified during this assessment. Detailed descriptions, evidence, and remediation guidance for each finding are provided in Section 5.

| ID      | Finding                                                                  | Severity | Source    |
|---------|--------------------------------------------------------------------------|----------|-----------|
| VULN-01 | Content Security Policy (CSP) Header Not Set                             | Medium   | OWASP ZAP |
| VULN-02 | Cross-Domain Misconfiguration                                            | Medium   | OWASP ZAP |
| VULN-03 | Exposed Server Status Page                                               | Medium   | OWASP ZAP |
| VULN-04 | Missing Anti-clickjacking Header                                         | Medium   | OWASP ZAP |
| VULN-05 | Vulnerable JS Library                                                    | Medium   | OWASP ZAP |
| VULN-06 | In Page Banner Information Leak                                          | Low      | OWASP ZAP |
| VULN-07 | Server Leaks Version Information via "Server" HTTP Response Header Field | Low      | OWASP ZAP |
| VULN-08 | X-Content-Type-Options Header Missing                                    | Low      | OWASP ZAP |
| VULN-09 | Expired SSL Certificate                                                  | High     | Nmap      |
| VULN-10 | SSLv2 Enabled                                                            | Critical | Nmap      |
| VULN-11 | Outdated, End-of-Life Software Stack                                     | High     | Nmap      |

---

|         |                                                            |        |           |
|---------|------------------------------------------------------------|--------|-----------|
| VULN-12 | Risky HTTP Methods (PUT/DELETE/TRACE/PATCH)                | Medium | Nmap      |
| VULN-13 | Weak Transport Security Due to Expired SSL/TLS Certificate | High   | Burpsuite |

---

## 4. Findings

---

### 4.1 VULN-01: Content Security Policy (CSP) Header Not Set

Affected URL : <https://zero.webappsecurity.com/robots.txt>

Severity level: Medium

#### Business Impact

*What it is:* No rule telling the browser which sources of scripts/styles/images are trusted.

*How a hacker exploits it:* On its own, this isn't directly exploitable. But if the hacker finds an injection point elsewhere (like XSS), CSP would normally have blocked the injected script from running or sending stolen data out. Without it, any injected script runs freely and can send cookies/data to the attacker's own server.

#### Remediation

- Add a Content-Security-Policy header that only allows scripts/styles/images from trusted sources (start with default-src 'self'). Test it in "report-only" mode first so it doesn't break the site, then switch it to enforced.

---

### 4.2 VULN-02: Cross-Domain Misconfiguration

Affected URL : <http://zero.webappsecurity.com/sitemap.xml>

Severity level: Medium

#### Business Impact

*What it is:* The server tells browsers "any website is allowed to read my response."

*How a hacker exploits it:* The hacker hosts their own malicious webpage. If a victim is logged into the real site and visits the hacker's page, JavaScript on that page can silently make a request to the real site and read back the response — including private account data, if this same wildcard header is set on sensitive endpoints (not just the public sitemap tested here).

#### Remediation

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

---

### 4.3 VULN-03: Exposed server-status Page

**Affected URL :** <http://zero.webappsecurity.com/server-status>

**Severity Level:** Medium

#### **Business Impact**

*What it is:* An internal admin monitoring page is open to the public.

*How a hacker exploits it:* The hacker simply visits /server-status and reads live data: visitor IP addresses, what URLs people are currently requesting, server load, and configuration details — using this as reconnaissance to map out the site's structure and behavior before launching a more targeted attack.

#### **Remediation**

Consider whether or not the component is actually required in production, if it isn't then disable it. If it is then ensure access to it requires appropriate authentication and authorization, or limit exposure to internal systems or specific source IPs, etc.

---

### 4.4 VULN-04: Missing Anti-clickjacking Header

**Affected URL :** <http://zero.webappsecurity.com/>

**Severity Level:** Medium

#### **Business Impact**

*What it is:* No header stops the site from being loaded inside someone else's webpage in an invisible iframe.

*How a hacker exploits it:* The hacker embeds the real site in a hidden iframe on their own page, then places fake buttons over it. The victim thinks they're clicking "Claim your prize," but they're actually clicking a real button on the underlying real site (like "Transfer funds" or "Confirm login") — the click passes through to the genuine page underneath.

#### **Remediation**

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

---

## 4.5 VULN-05: Vulnerable JS Library

**Affected URL :** <http://zero.webappsecurity.com/resources/js/jquery-1.8.2.min.js>

**Severity Level:** Medium

### **Business Impact**

*The identified library jquery, version 1.8.2 is vulnerable.*

CVE-2020-11023

CVE-2020-11022

CVE-2015-9251

CVE-2019-11358

CVE-2020-7656

CVE-2012-6708

### **Remediation**

Upgrade to the latest version of the affected library.

## 4.6 VULN-06: In Page Banner Information Leak

**Affected URL :** <http://zero.webappsecurity.com/sitemap.xml>

**Severity Level:** Low

### **Business Impact**

*The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.*

### **Remediation**

Configure the server to prevent such information leaks. For example:

Under Tomcat this is done via the "server" directive and implementation of custom error pages.

Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.



---

## 4.7 VULN-07: Server Leaks Version Information via "Server" HTTP Response Header Field

Affected URL : <http://zero.webappsecurity.com/sitemap.xml>

**Severity Level: Low**

### Business Impact

*The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.*

### Remediation

Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.

## 4.8 VULN-08: X-Content-Type-Options Header Missing

Affected URL : <http://zero.webappsecurity.com/>

**Severity Level: Low**

### Business Impact

*The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.*

### Remediation

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

---

## 4.9 VULN-09: Expired SSL Certificate

**Severity Level: HIGH**

### **Business Impact**

*What it is: The certificate proving "this is really the legitimate site" expired years ago.*

*How a hacker exploits it: On a network the hacker controls or can intercept (e.g., public WiFi), they can present their own fake certificate instead. Since the real certificate is already expired and browsers/users are somewhat conditioned to click through warnings, a victim is more likely to ignore the warning and connect to the hacker's impersonating server, exposing their traffic (man-in-the-middle).*

### **Remediation**

Renew and replace the expired SSL/TLS certificate immediately, enable automatic certificate renewal, and continuously monitor certificate expiry dates to prevent service disruption and reduce the risk of man-in-the-middle attacks.

## 4.10 VULN-10: SSLv2 Enabled

Severity Level: Critical

### **Business Impact**

*What it is: The server still accepts an ancient, broken encryption protocol and very weak ciphers.*

*How a hacker exploits it: Using a known attack like DROWN, a hacker intercepting encrypted traffic can force the connection to use the weak SSLv2 protocol, exploit its cryptographic flaws, and decrypt data that was supposed to be private — including, in real-world DROWN cases, traffic from a separate stronger connection sharing the same key.*

### **Remediation**

Disable SSLv2 and use only TLS 1.2/1.3.

## 4.11 VULN-11: Outdated, End-of-Life Software Stack

Severity Level: HIGH

### **Business Impact**

*What it is: Apache, OpenSSL are all old versions no longer receiving security patches.*

*How a hacker exploits it: The hacker identifies the exact versions running (via banners/headers), searches for public exploits matching those specific versions (since they're EOL, there will never be a vendor patch), and runs an existing, ready-made exploit against the unpatched flaw.*

### **Remediation**

---

Upgrade OpenSSL AND Apache to a supported version and apply security patches.

## 4.12 VULN-12: Risky HTTP Methods (PUT/DELETE/TRACE/PATCH)

Severity Level: MEDIUM

### Business Impact

*What it is: The server accepts HTTP request types beyond normal GET/POST.*

*How a hacker exploits it: If PUT isn't properly locked down, the hacker can send a PUT request to upload a malicious file (like a web shell) directly onto the server. With TRACE enabled, combined with an XSS bug elsewhere, the hacker can use Cross-Site Tracing to read HTTP headers/cookies that should otherwise be hidden from JavaScript.*

### Remediation

Disable unnecessary HTTP methods and restrict them through server configuration.

## 4.13 VULN-13: Weak Transport Security Due to Expired SSL/TLS Certificate

Severity Level: HIGH

### Business Impact

*User credentials are transmitted as plaintext form parameters within the HTTP POST request.*

*While this is standard web application behavior, the expired SSL/TLS certificate reduces the reliability of transport-layer authentication and may increase the risk of credential interception if users ignore certificate warnings.*

### Remediation

Renew and replace the expired SSL/TLS certificate with a valid certificate issued by a trusted Certificate Authority (CA). Disable the use of expired certificates, implement automated certificate renewal and monitoring, and ensure all authentication traffic is transmitted over properly validated HTTPS connections using modern TLS versions.

---

## 5. Conclusion & Recommendations

---

### 5.1 Prioritized Remediation Roadmap

| Priority | Action                               | Target Timeline |
|----------|--------------------------------------|-----------------|
| 1        | Remediate Critical/High findings     | 0–7 days        |
| 2        | Remediate Medium findings            | 30 days         |
| 3        | Remediate Low/Informational findings | 90 days         |